

Data re-identification or de-anonymization is the practice of matching anonymous data (also known as de-identified data) with publicly available information, or auxiliary data, in order to discover the person to whom the data belongs. This is a concern because companies with privacy policies, health care providers, and financial institutions may release the data they collect after the data has gone through the de-identification process.

The de-identification process involves masking, generalizing or deleting both direct and indirect identifiers; the definition of this process is not universal. Information in the public domain, even seemingly anonymized, may thus be re-identified in combination with other pieces of available data and basic computer science techniques. The Protection of Human Subjects ('Common Rule'), a collection of multiple U.S. federal agencies and departments including the U.S. Department of Health and Human Services, warn that re-identification is becoming gradually easier because of "big data"—the abundance and constant collection and analysis of information along with the evolution of technologies and the advances of algorithms. However, others have claimed that de-identification is a safe and effective data liberation tool and do not view re-identification as a concern.

More and more data are becoming publicly available over the Internet. These data are released after applying some anonymization techniques like removing personally identifiable information (PII) such as names, addresses and social security numbers to ensure the sources' privacy. This assurance of privacy allows the government to legally share limited data sets with third parties without requiring written permission. Such data has proved to be very valuable for researchers, particularly in health care.

GDPR-compliant pseudonymization seeks to reduce the risk of re-identification through the use of separately kept "additional information". The approach is based on an expert evaluation of a dataset to designate some identifiers as "direct" and some as "indirect." Proponents of this approach argue that re-identification can be avoided by limiting access to "additional information" that is kept separately by the controller. The theory is that access to

separately kept "additional information" is required for re-identification, attribution of data to a specific data subject can be limited by the controller to support lawful purposes only. This approach is controversial, as it fails if there are additional datasets that can be used for re-identification. Such additional datasets may be unknown to those certifying the GDPR-compliant pseudonymization, or may not exist at the time of the pseudonymization but may come into existence at some point in the future.

Legal protections of data in the United States

Existing privacy regulations typically protect information that has been modified, so that the data is deemed anonymized, or de-identified. For financial information, the Federal Trade Commission permits its circulation if it is de-identified and aggregated. The Gramm Leach Bliley Act (GLBA), which mandates financial institutions give consumers the opportunity to opt out of having their information shared with third parties, does not cover de-identified data if the information is aggregate and does not contain personal identifiers, since this data is not treated as personally identifiable information.

Educational records

In terms of university records, authorities both on the state and federal level have shown an awareness about issues of privacy in education and a distaste for institutions' disclosure of information. The U.S. Department of Education has provided guidance about data disclosure and identification, instructing educational institutions to be sensitive to the risk of re-identification of anonymous data by cross-referencing with auxiliary data, to minimize the amount of data in the public domain by decreasing publication of directory information about students and institutional personnel, and to be consistent in the processes of de-identification.

Medical records

Medical information of patients are becoming increasingly available on the Internet, on free and publicly accessing platforms such as HealthData.gov and PatientsLikeMe, encouraged by government open data policies and data sharing initiatives spearheaded by the private sector.

While this level of accessibility yields many benefits, concerns regarding discrimination and privacy have been raised. Protections on medical records and consumer data from pharmacies are stronger compared to those for other kinds of consumer data. The Health Insurance Portability and Accountability Act (HIPAA) protects the privacy of identifiable data about health, but authorize information release to third parties if de-identified. In addition, it mandates that patients receive breach notifications should there be more than a low probability that the patient's information was inappropriately disclosed or utilized without sufficient mitigation of the harm to him or her. The likelihood of re-identification is a factor in determining the probability that the patient's information has been compromised. Commonly, pharmacies sell de-identified information to data mining companies that sell to pharmaceutical companies in turn.

There have been state laws enacted to ban data mining of medical information, but they were struck down by federal courts in Maine and New Hampshire on First Amendment grounds. Another federal court on another case used "illusive" to describe concerns about privacy of patients and did not recognize the risks of re-identification.

Biospecimen

The Notice of Proposed Rule Making, published by the Common Rule Agencies in September 2015, expanded the umbrella term of "human subject" in research to include biospecimens, or materials taken from the human body - blood, urine, tissue etc. This mandates that researchers using biospecimens must follow the stricter requirements of doing research with human subjects. The rationale for this is the increased risk of re-identification of biospecimen. The final revisions affirmed this regulation.

Re-identification efforts

There have been a sizable amount of successful attempts of re-identification in different fields. Even if it is not easy for a lay person to break anonymity, once the steps to do so are disclosed and learnt, there is no need for higher level knowledge to access information in a database. Sometimes, technical expertise is not even needed if a population has a unique combination of identifiers.

Health records

In the mid-1990s, a government agency in Massachusetts called Group Insurance Commission (GIC), which purchased health insurance for employees of the state, decided to release records of hospital visits to any researcher who requested the data, at no cost. GIC assured that the patient's privacy was not a concern since it had removed identifiers such as name, addresses, social security numbers. However, information such as zip codes, birth date and sex remained untouched. The GIC assurance was reinforced by the then governor of Massachusetts, William Weld. Latanya Sweeney, a graduate student at the time, put her mind to picking out the governor's records in the GIC data. By combining the GIC data with the voter database of the city Cambridge, which she purchased for 20 dollars, Governor Weld's record was discovered with ease.

In 1997, a researcher successfully de-anonymized medical records using voter databases.

In 2011, Professor Latanya Sweeney again used anonymized hospital visit records and voting records in the state of Washington and successfully matched individual persons 43% of the time.

There are existing algorithms used to re-identify patient with prescription drug information.

Consumer habits and practices

Two researchers at the University of Texas, Arvind Narayanan and Professor Vitaly Shmatikov, were able to re-identify some portion of anonymized Netflix movie-ranking data with individual consumers on the streaming website. The data was released by Netflix 2006 after de-identification, which consisted of replacing individual names with random numbers and moving around personal details. The two researchers de-anonymized some of the data by comparing it with non-anonymous IMDb (Internet Movie Database) users' movie ratings. Very little information from the database, it was found, was needed to identify the subscriber. In the resulting research paper, there were startling revelations of how easy it is to re-identify Netflix users. For example, simply knowing data about only two movies a user has reviewed, including the precise rating and the date of rating give or take three days allows for 68% re-identification success.

In 2006, after AOL published its users' search queries, data that was anonymized prior to the public release, The New York Times reporters successfully carried out re-identification of individuals by taking groups of searches made by anonymized users. AOL had attempted to suppress identifying information, including usernames and IP addresses, but had replaced these with unique identification numbers to preserve the utility of this data for researchers. Bloggers, after the release, pored over the data, either trying to identify specific users with this content, or to point out entertaining, depressing, or shocking search queries, examples of which include "how to kill you wife", "depression and medical leave", "car crash photos." Two reporters, Michael Barbaro and Tom Zeller, were able to track down a 62 year old widow named Thelma Arnold from recognizing clues to the identity of User 417729 search histories. Arnold acknowledged that she was the author of the searches, confirming that re-identification is possible.

Location data

Location data - series of geographical positions in time that describe a person's whereabouts and movements - is a class of personal data that is specifically hard to keep anonymous. Location shows recurring visits to frequently attended places of everyday life such as home, workplace, shopping, healthcare or specific spare-time patterns. Only removing a person's identity from location data will not remove identifiable patterns such as commuting rhythms, sleeping places, or work places. By mapping coordinates onto addresses, location data is easily re-identified or correlated with a person's private life contexts. Streams of location information play an important role in the reconstruction of personal identifiers from smartphone data accessed by apps.

Court decisions

In 2019, Professor Kerstin Noëlle Vokinger and Dr. Urs Jakob Mühlematter, two researchers at the University of Zurich, analyzed cases of the Federal Supreme Court of Switzerland to assess which pharmaceutical companies and which medical drugs were involved in legal actions against the Federal Office of Public Health (FOPH) regarding pricing decisions of medical drugs. In general, involved private parties (such as pharmaceutical companies) and information that would reveal the private party (for example, drug names) are anonymized in Swiss judgments. The researchers were able to re-identify 84% of the relevant anonymized cases of the Federal Supreme Court of Switzerland by linking information from publicly accessible databases. This achievement was covered by the media and started a debate if and how court cases should be anonymized.

Concern and consequences

In 1997, Latanya Sweeney found from a study of Census records that up to 87 percent of the U.S. population can be identified using a combination of their 5-digit zip code, gender, and date of birth.

Unauthorized re-identification on the basis of such combinations does not require access to separately kept "additional information" that is under the control of the data controller, as is now required for GDPR-compliant pseudonymization.

Individuals whose data is re-identified are also at risk of having their information, with their identity attached to it, sold to organizations they do not want possessing private information about their finances, health or preferences. The release of this data may cause anxiety, shame or embarrassment. Once an individual's privacy has been breached as a result of re-identification, future breaches become much easier: once a link is made between one piece of data and a person's real identity, any association between the data and an anonymous identity breaks the anonymity of the person.

Re-identification may expose companies and institutions which have pledged to assure anonymity to increased tort liability and cause them to violate their internal policies, public privacy policies, and state and federal laws, such as laws concerning financial confidentiality or medical privacy, by having released information to third parties that can identify users after re-identification.

Remedies

To address the risks of re-identification, several proposals have been suggested:

Higher standards and uniform definition of de-identification while retaining data utility: the definition of de-identification should balance privacy protections to reduce re-identification risk with the refusal of companies to delete data

Heightened privacy protections of anonymized information

Tighter security for databases that store anonymized information

Strong ban on malicious re-identification, the passing of broader anti-discrimination and privacy legislation that ensures privacy protections as well as encourage participation in data

sharing projects and endeavors, as well as establishment of uniform data protection standards in academic communities, such as in the scientific community, in order to minimize privacy violations

Creation of data-release policies: making sure de-identification rhetoric is accurate, drawing up contracts that prohibit re-identification attempts and dissemination of sensitive information, establishing data enclaves, and utilizing data-based strategies to match required protection standards to the level of risk.

Implementation of Differential Privacy on requested data sets

Generation of Synthetic Data that exhibits the statistical properties of the raw data, without allowing real individuals to be identified

While a complete ban on re-identification has been urged, enforcement would be difficult. There are, however, ways for lawmakers to combat and punish re-identification efforts, if and when they are exposed: pair a ban with harsher penalties and stronger enforcement by the Federal Trade Commission and the Federal Bureau of Investigation; grant victims of re-identification a right of action against those who re-identify them; and mandate software audit trails for people who utilize and analyze anonymized data. A small-scale re-identification ban may also be imposed on trusted recipients of particular databases, such as government data miners or researchers. This ban would be much easier to enforce and may discourage re-identification.

Examples of de-anonymization

"Researchers at MIT and the Université catholique de Louvain, in Belgium, analyzed data on 1.5 million cellphone users in a small European country over a span of 15 months and found that just four points of reference, with fairly low spatial and temporal resolution, was enough to uniquely identify 95 percent of them. In other words, to extract the complete location information for a single person from an "anonymized" data set of more than a million people,

all you would need to do is place him or her within a couple of hundred yards of a cellphone transmitter, sometime over the course of an hour, four times in one year. A few Twitter posts would probably provide all the information you needed, if they contained specific information about the person's whereabouts."

"Here, we report that surnames can be recovered from personal genomes by profiling short tandem repeats on the Y chromosome (Y-STRs) and querying recreational genetic genealogy databases. We show that a combination of a surname with other types of metadata, such as age and state, can be used to triangulate the identity of the target."

See also

== References ==